

تقرير مشروع VulnScanner Pro (الإصدار المتقدم)

1. المقدمة (الزبدة)

مشروع VulnScanner Pro هو ماسح ثغرات أمني أكاديمي متقدم، تم تطويره ليكون أداة دفاعية شاملة وعميقة. يركز هذا الإصدار على “الزبدة الفنية”، حيث تم حذف الحشو الزائد والتركيز المباشر على اكتشاف الثغرات المعقدة، تحليل المنطق البرمجي، وتوفير طرق استغلال عملية ومختصرة لكل ثغرة.

2. محرك الفحص العميق (Deep Scan Engine)

تمت إضافة محرك فحص جديد (`deep_scanner.py`) يقوم بتحليل شامل وعميق لمحتوى الصفحات والترويسات، ويشمل:

- فحص أمان JavaScript:** كشف مفاتيح API المسربة، والدوال الخطرة مثل `eval()` و `innerHTML`.
- فحص قواعد البيانات:** رصد استعلامات SQL المكشوفة في الكود.
- فحص المصادقة (Authentication):** كشف غياب حماية CSRF، النماذج غير الآمنة، وضعف إعدادات الكوكيز.
- فحص التبعية (Dependencies):** تحديد المكتبات القديمة (مثل jQuery 1.x) التي تحتوي على ثغرات معروفة.
- فحص الثغرات المنطقية:** رصد ضعف التحقق من الصلاحيات والمدخلات.

3. قاعدة بيانات الثغرات المتقدمة

تم توسيع قاعدة البيانات (`vulnerabilities_db.py`) لتشمل ثغرات أكثر تعقيداً مع التركيز على خطوات الاستغلال المباشرة:

الثغرة	الخطورة	طريقة الاستغلال (الزبدة)	Payload مثال
SQL Injection	حرجة	حقن أوامر SQL في حقول الإدخال لاستخراج البيانات.	-- OR 1=1 '
XSS	عالية	حقن كود JS في الحقول المعروضة لسرقة الجلسات.	<script>alert(1)</script>
RCE	حرجة	حقن أوامر النظام عبر ; أو \ للسيطرة على السيرفر.	whoami ;
IDOR	عالية	تغيير معرف المورد في URL للوصول لبيانات مستخدم آخر.	id=101 -> ?id=102?
LFI / RFI	عالية	تضمين ملفات النظام عبر . . / أو كود خارجي.	etc/passwd/
SSRF	عالية	إجبار السيرفر على طلب موارد داخلية للوصول للشبكة.	http://169.254.169.254
XXE	عالية	حقن كيانات XML خارجية لقراءة ملفات السيرفر.	ENTITY xxe SYSTEM!><'file:///etc/passwd

4. واجهة التقرير المحسنة

تم إعادة تصميم واجهة التقرير (report_renderer.py) لتكون أكثر احترافية واختصاراً:

- **تصميم نظيف:** واجهة تعتمد على البطاقات (Cards) لعرض المعلومات بوضوح.
- **التركيز على الاستغلال:** إبراز قسم "طريقة الاستغلال" و "Payload" لكل ثغرة بشكل مميز.
- **حذف الحشو:** إزالة النصوص الطويلة والتركيز على الأثر الفني المباشر.

5. الخلاصة

يقدم VulnScanner Pro في إصداره المتقدم أداة فحص قوية وشاملة، تجمع بين عمق التحليل التقني وسهولة قراءة النتائج. من خلال التركيز على "الزبدة" وتوفير طرق استغلال عملية، يعتبر المشروع مرجعاً أكاديمياً وعملياً ممتازاً لفهم وتأمين تطبيقات الويب.